

APKGraph

Android Attack Surface Intelligence Platform

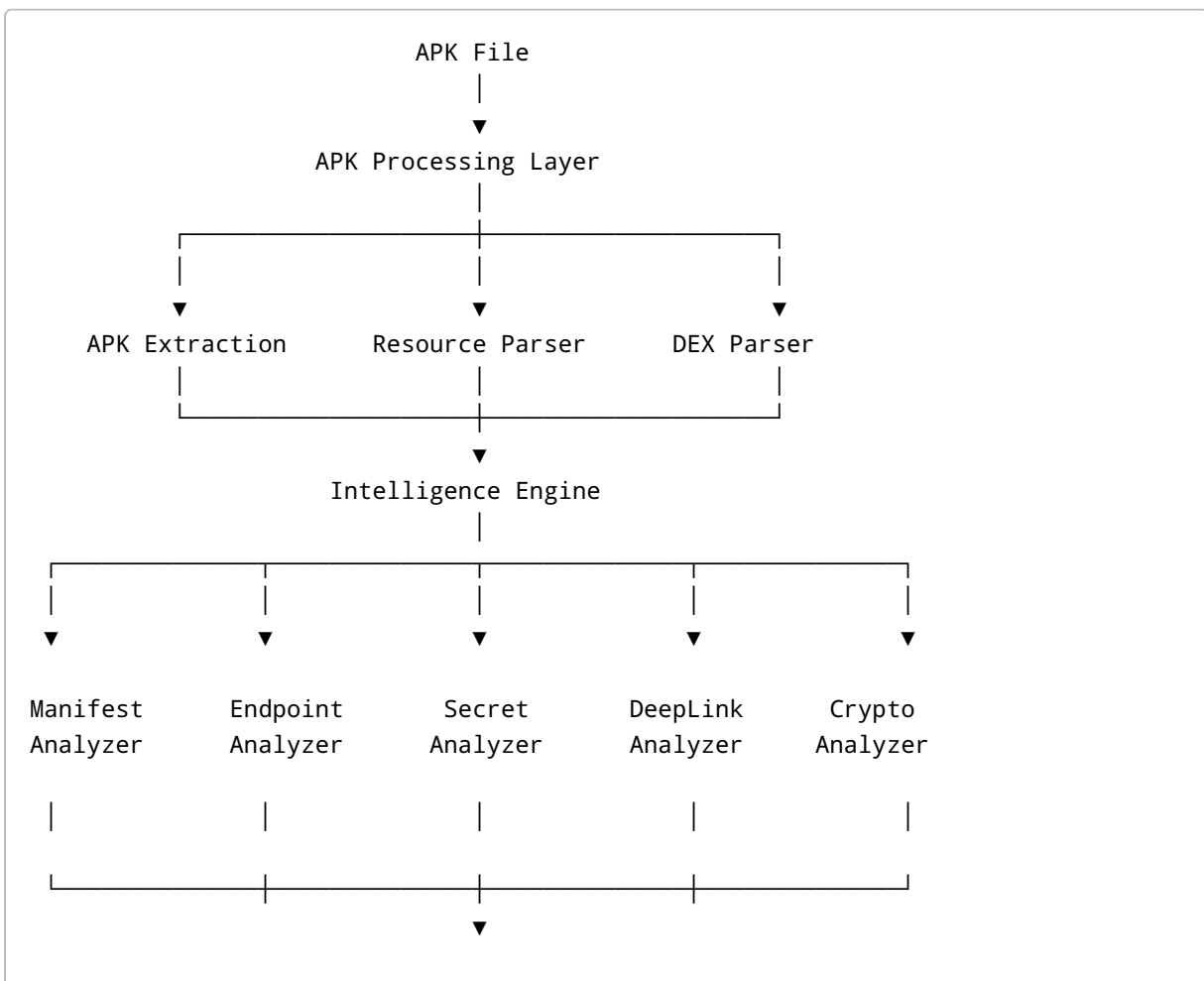
Vision

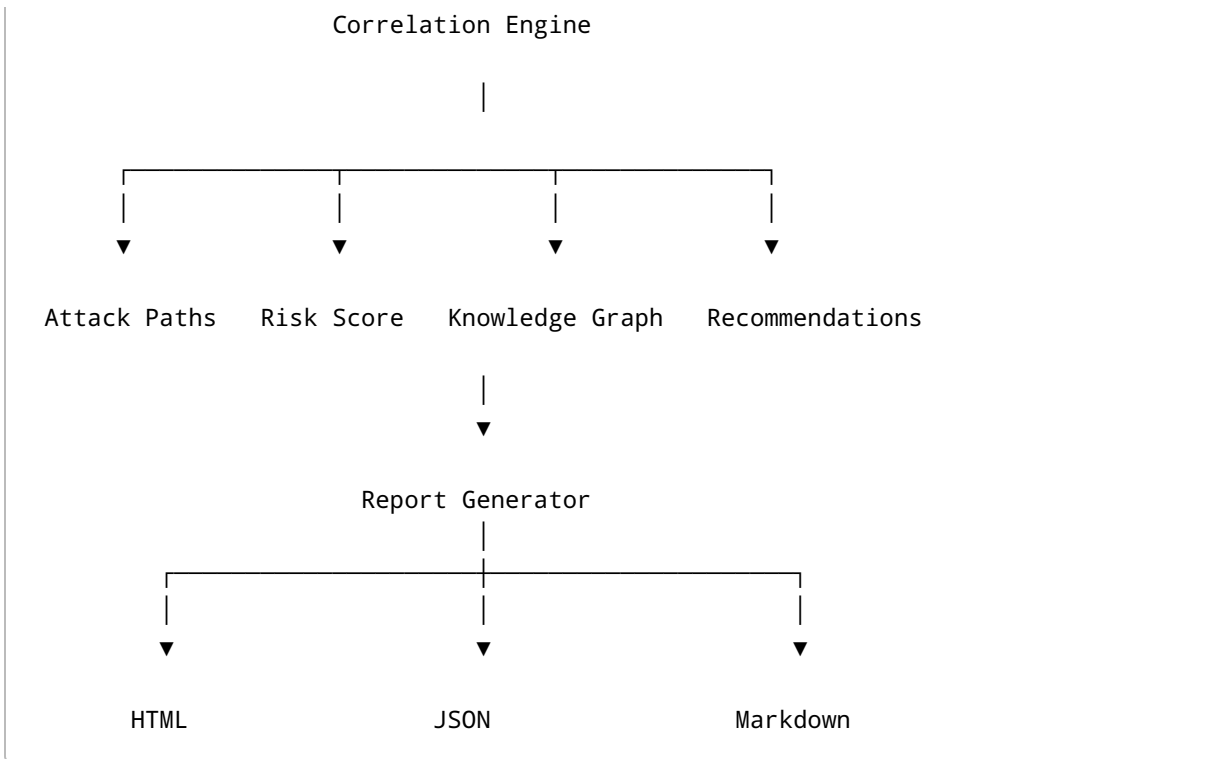
APKGraph is not another APK analyzer.

The goal is to transform an Android application into a complete attack surface graph that helps penetration testers, VAPT analysts, mobile security researchers, and bug bounty hunters understand how an application can be attacked.

Instead of producing thousands of findings, APKGraph correlates components and predicts attack paths.

High Level Architecture





Core Components

1. APK Processing Layer

Purpose

Convert APK into analyzable artifacts.

Responsibilities

- APK extraction
- DEX extraction
- Resource parsing
- Manifest extraction
- Native library collection
- Asset extraction

Output

```
{
  "manifest": {},
  "classes": [],
  "resources": [],
```

```
"libraries": []  
}
```

2. Manifest Intelligence Module

Responsibilities

Analyze:

- Activities
- Services
- Broadcast Receivers
- Content Providers
- Permissions
- Exported Components
- Intent Filters

Findings

```
{  
  "exported_components": [],  
  "dangerous_permissions": [],  
  "custom_permissions": []  
}
```

3. Endpoint Intelligence Module

Purpose

Discover application backend infrastructure.

Detection Sources

- Retrofit
- Volley
- OkHttp
- GraphQL
- Hardcoded URLs
- WebSocket endpoints

Classification

```
Authentication
User APIs
Admin APIs
Payment APIs
Internal APIs
GraphQL APIs
WebSocket APIs
```

4. Environment Discovery Engine

Purpose

Identify hidden environments.

Target Environments

```
Production
Staging
QA
UAT
Testing
Internal
Sandbox
Development
PreProduction
```

Example

```
api.company.com
staging-api.company.com
internal-api.company.com
```

5. Deep Link Intelligence Module

Responsibilities

Extract:

- URI Schemes
- App Links
- Universal Links
- Intent Filters

Risk Detection

- Authentication bypass opportunities
 - Unauthorized navigation
 - Sensitive activity exposure
-

6. Secret Intelligence Module

Responsibilities

Detect:

- API Keys
- OAuth Secrets
- JWT Secrets
- Firebase Keys
- AWS Keys
- Encryption Keys
- Database Credentials

Confidence Engine

Every finding receives:

High
Medium
Low

confidence ratings.

7. Crypto Intelligence Module

Detection Targets

Weak Algorithms

```
MD5  
SHA1  
DES  
3DES  
RC4
```

Weak Configurations

```
AES ECB  
Static IV  
Hardcoded Key  
Predictable Random
```

Output

```
{  
  "risk": "High",  
  "algorithm": "AES",  
  "mode": "ECB"  
}
```

8. SSL Pinning Intelligence

Detect

```
CertificatePinner  
TrustManager  
TrustKit  
Conscrypt  
Network Security Config
```

Output

```
{  
  "pinning": true,  
  "framework": "OkHttp"  
}
```

9. Root Detection Intelligence

Detect

```
RootBeer  
Magisk Detection  
SU Detection  
BusyBox Detection  
Frida Detection  
Debugger Detection
```

Purpose

Identify application hardening controls.

10. WebView Security Analyzer

Detect

```
JavaScript Interfaces  
File Access  
Universal Access  
Content Access  
Mixed Content
```

Attack Surface

```
WebView  
↓  
JS Bridge  
↓  
Native Functions
```

11. Hidden Function Discovery

Purpose

Discover undocumented functionality.

Targets

```
Admin
Debug
Developer
Internal
Support
Moderator
Testing
QA
```

Examples

```
DeveloperActivity
AdminPanelActivity
DebugMenuActivity
```

12. SDK Fingerprinting Engine

Identify

```
Firebase
AWS
Azure
OneSignal
Mixpanel
Branch
AppsFlyer
CleverTap
MoEngage
Amplitude
```

Output

Third-party attack surface inventory.

13. JWT Intelligence Module

Detect

```
Access Tokens
Refresh Tokens
JWT Claims
Role Claims
Authorization Logic
```

Analysis

- Role mapping
- Permission mapping
- Trust relationships

Knowledge Graph Engine

Purpose

Convert all findings into relationships.

Example

```
Application
|
├─ Login Activity
|
├─ Deep Link
|
├─ JWT Token
|
├─ Admin API
|
└─ Firebase
```

This becomes the foundation for attack path generation.

Attack Path Prediction Engine

Purpose

Correlate findings and predict exploitation opportunities.

Example

```
Deep Link
↓
Authentication Bypass
↓
JWT Exposure
↓
Admin API Access
↓
Sensitive Data Exposure
```

Confidence Scoring

```
Low
Medium
High
Critical
```

Risk Scoring Engine

Formula

```
Risk =
Attack Surface Exposure
+
Sensitive Assets
+
Authentication Weaknesses
+
Cryptographic Weaknesses
+
Privilege Escalation Potential
```

Output

0-25	Low
26-50	Medium
51-75	High
76-100	Critical

Report Generator

Outputs

HTML

Interactive dashboard.

Markdown

GitHub-friendly report.

JSON

Machine-readable findings.

Future Roadmap

v2

- Frida script generation
- Automatic attack path validation
- APK comparison engine
- Android malware heuristics
- AI-assisted pentest recommendations

v3

- Dynamic analysis support
- Emulator integration
- Runtime API tracing
- Traffic correlation
- Hybrid static + dynamic attack graph generation

Project Goal

Turn this:

10,000 APK strings
500 URLs
200 Activities

Into this:

Potential Attack Path #1

Deep Link

↓

Authentication Bypass

↓

JWT Access

↓

Admin API

↓

Sensitive Data Exposure

Confidence: 91%

APKGraph focuses on attack intelligence, not finding dumps.